INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Schnitzer CNC Ahşap Torna Sürümü

Tüm laboratuvarlar tek bir gerçek makine üzerinde işlenir: **Schnitzer 2 Eksen 2 Ünite CNC Ahşap Torna** (Kestel / Bursa). Siemens CNC (SINUMERIK 808D) · 4 kW iş mili · X/Z servo eksenler · FESTO pnömatik punta · USB + Ethernet · uzaktan üretici desteği.

Yusuf Kaymaz · 230541084 · Gündüz-B · 06.11.2026

LAB 1 · Safety Architecture	Çıktı: Safety Function Map	✓
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram	✓
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register	✓
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture	✓
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision	✓
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow	✓
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision	✓
SWOT Analizi	Çıktı: Stratejik değerlendirme	✓

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurulan föyler Machine Starter Pack'in parçasıdır.

LABORATUVAR 1 · SCHNITZER 2×2 · CNC Ahşap Torna

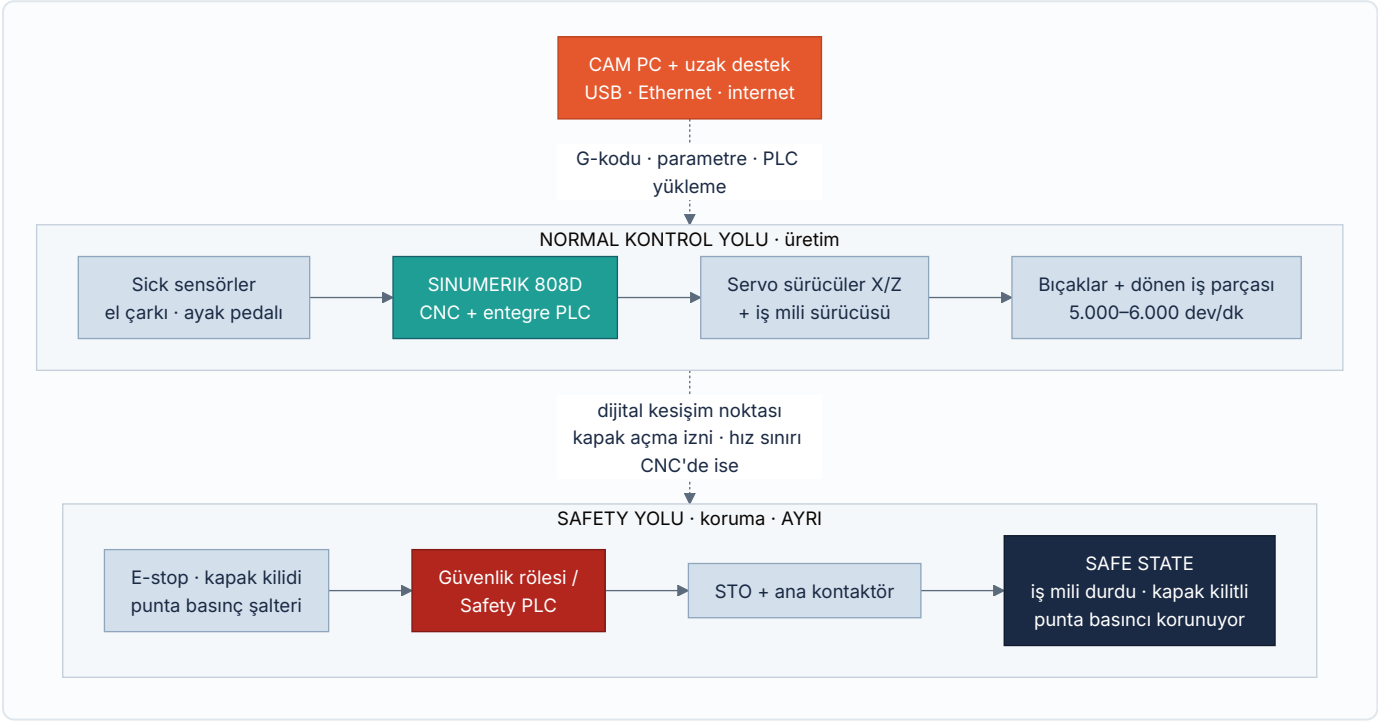
Safety Architecture

Çıktı: Safety Function Map

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	23.10.2026

Schnitzer bağlamı: 5.000–6.000 dev/dk dönen ahşap iş parçası ve 75 m/dk hızla hareket eden bıçak taşıyıcı el, kol ve kıyafet için ciddi tehlikedir. Koruma zinciri: **E-stop + kapak kilidi + punta basınç kontrolü → güvenlik rölesi / Safety PLC → STO + ana kontaktör**. Programlar USB ve Ethernet ile yükleniyor, üretici desteği uzaktan veriliyor. Sorular bu **dijital kesişim noktasına** gidecek.

Safety Function Map



Kırmızı kutu (Safety PLC / güvenlik rölesi) ve alttaki yol, **safety-related control system (SRCS)**'dir. Turuncu kutu, dışarıdan erişilebilen dijital kapıdır. Kesikli çizgiler, siber müdahalenin emniyet zincirine dokunabildiği yerleri gösterir.

Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

- **Dönen iş parçası (5.000–6.000 dev/dk):** kol, eldiven, saç veya kıyafet dolanır (yakalanma). Ağır ve kalıcı yaralanma.
- **Bıçaklar ve bıçak taşıyıcı:** V-bıçak ve çanak bıçakla kesilme. Taşıyıcı 75 m/dk hızla hareket ettiği için çarpma ve ezilme.
- **Fırlayan parça:** punta sıkması gevşerse, kütük çatlak/budaklıysa veya hız parçaya göre fazlaysa iş parçası ya da kopan parçası fırlar. Yüze, göze ve vücuda çarpma.
- **Pnömatik merkezleme ve punta:** ayak pedalıyla kapanırken parmak sıkışması.
- **İkincil:** ahşap tozu (solunum, yangın), gürültü.

Operatör en çok **parça yüklerken veya alırken**, ölçü kontrolünde ve talaş temizliğinde, yani kapak açıkken tehlikeye yaklaşır.

2 Safety function (emniyet fonksiyonu) hangisidir?

ID	Emniyet fonksiyonu	Önlediği tehlike
SF-1	**Acil durdurma (E-stop):** basılınca iş mili ve eksenlerin enerjisi kesilir	Tüm tehlikeler (tamamlayıcı koruma)
SF-2	**Kapak kilidi:** kapak açıkken iş mili ve eksenler çalışamaz, iş mili tamamen durmadan kapak açılamaz	Dolanma, kesilme, çarpma
SF-3	**Punta basınç izleme:** sıkma basıncı yetersizse iş mili başlamaz veya durdurulur	Parça fırlaması
SF-4	**İş mili azami hız sınırı:** parça çapına uygun hız aşılamaz	Parçanın çatlayıp fırlaması

Ana fonksiyon **SF-2**: operatör kapağı her parçada açtığı için hem en sık erişim hem de en ağır sonuç buradadır.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki alttaki ayrı yol: **E-stop + kapak kilidi + punta basınç şalteri (giriş) → güvenlik rölesi / Safety PLC (mantık) → STO + ana kontaktör (çıkış)**. SINUMERIK 808D'nin entegre PLC'si, CAM PC ve uzak destek bu sistemin parçası **değildir**. Ancak kapak açma izni veya hız sınırı CNC'de hesaplanıyorsa (VS-3), o kısım fiilen emniyet zincirine dahil olur ve korunmasız kalır.

4 CNC kontrolör (SINUMERIK 808D – entegre PLC) ile güvenlik rölesi / Safety PLC farkı nedir? UYARLANDI

808D'nin entegre PLC'si **üretimi** yönetir: G-kodunu işler, eksenleri ve iş milini sürer, M-kodlarıyla pnömatiği açıp kapatır. Emniyet sınıfı (PL/SIL) sertifikası yoktur, tek kanallıdır, USB ve Ethernet üzerinden programlanabilir ve parametreleri değiştirilebilir. Güvenlik rölesi / Safety PLC ise **sertifikalıdır** (PL d/e), çift kanallı çalışır, kendini ve kablolamayı sürekli test eder, arıza görünce makineyi güvenli duruma alır ve yalnızca emniyet fonksiyonunu yürütür. Kısaca: üst yol üretim için, alt yol hayat için.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr/SIL, bir emniyet fonksiyonunun riske göre **ne kadar güvenilir** olması gerektiğini belirler. Kapak kilidi (SF-2) için: **şiddet S2** (dolanma ağır ve kalıcı yaralanma yapar), **sıklık F2** (operatör her parçada kapağı açar), **kaçınma P2** (5.000 dev/dk'da kaçmak neredeyse imkânsız). ISO 13849-1 risk grafiğinde bu yol **PLr e**'ye çıkar. Bu güvenilirlik güvenlik rölesinin / Safety PLC'nin konfigürasyonuna bağlıdır: konfigürasyon değişirse performans da değişir.

6 Safe state (güvenli durum) nedir?

Güvenli durum bağlama bağlıdır. Bu tornada:

- İş mili ve eksenler **durmuş**, sürücülerin enerjisi STO ile kesilmiş;
- Kapak, iş mili **tamamen durana kadar kilitli**;
- Punta **basıncı korunuyor**. Parça hâlâ dönerken sıkma bırakılırsa parça fırlar, yani pnömatikte güvenli durum "enerjiyi kes" değil "konumu koru"dur;
- Makine, kapak kapanıp reset verilmeden kendiliğinden yeniden çalışmaz.

7 **Safety function hangi dijital bağımlılıklara sahip?**

- 808D entegre PLC programı (kapak açma izni ve punta basınç kontrolü burada ise)
- Makine parametreleri (iş mili azami hızı, eksen hız ve ivme sınırları)
- G-kodu programı (S = iş mili hızı, F = ilerleme, koordinatlar)
- Servo ve iş mili sürücülerinin parametreleri ve firmware'i
- Güvenlik rölesi / Safety PLC konfigürasyonu (programlanabilir tipse)
- Üreticinin CAM yazılımı ve CAM PC (G-kodunu üretir)
- Yükleme yolları: USB portu, Ethernet, uzak destek bağlantısı

8 **Siber müdahale hangi noktadan bu fonksiyonu bozar?**

Dijital kesişim noktası: CNC'ye (808D) program, parametre veya PLC yazılabilen yol, yani USB portu, Ethernet ve CAM PC üzerindeki uzak destek bağlantısı. Buradan iş mili hız sınırı yükseltilebilir (SF-4). Kapak açma izni CNC'de ise kapak dönen parçada açılabilir (SF-2), punta basınç kontrolü de atlanabilir (SF-3). En riskli yol: **internete açık uzak destek → CAM PC → Ethernet → 808D**.

Ek sorularımız

9 **STO devreye girince dönen iş parçası hemen durur mu? Bu neden önemli?** EK SORU

Hayır. STO yalnızca motora giden torku keser (IEC 60204-1 durma kategorisi 0). 4 kW'lık iş mili ve ahşap kütük, fren yoksa ataletle **saniyelerce dönmeye devam eder**. Bu süre operatörün kapağı açıp elini uzatma süresinden uzunsa kapak kilidi yalnızca "kapak kapalı" bilgisine değil, **iş milinin gerçekten durduğunun doğrulanmasına** bağlı olmalıdır. Diğer seçenek: önce kontrollü frenleme, sonra STO (SS1).

10 **G-kodu programı neden emniyetle ilgilidir?** EK SORU

G-kodu bir emniyet fonksiyonu değildir ama emniyet fonksiyonlarına **yük bindirir**: S komutu iş mili hızını, F ilerlemeyi, koordinatlar bıçağın nereye gideceğini belirler. Parça çapına göre fazla hız kütüğü çatlatıp fırlatabilir, yanlış koordinat bıçağı puntaya çarptırabilir. Bu yüzden hız sınırı (SF-4) programdan ve CNC parametresinden **bağımsız** olmalı, programlar çalıştırılmadan önce 3D önizleme ve kuru çalıştırma ile kontrol edilmelidir.

Varsayımlar

VS-1, VS-2 ve VS-3 bu föyde kullanıldı (bkz. Makine Profili). Kapak kilidinin tipi ve güvenlik rölesi mimarisi sahada doğrulanacak.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 2 · SCHNITZER 2×2 · CNC Ahşap Torna

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	23.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. Conduit = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz, mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi — saldırı yüzeyi altı kategoriyle

UYARLANDI

Föyde hazır bir liste yoktu. Bu makinenin listesini ders yöntemine göre **altı kategoriyle** biz çıkardık. İlk bakışta "bir makine, bir CNC" görünüyor; sistematik sayımla **28 kalem ve 3 dış bağlantı** çıktı.

Kategori	Varlıklar / kapılar
1 · Donanım	D-1 SINUMERIK 808D (CNC + entegre PLC + kumanda paneli) · D-2 servo sürücüler X/Z + servo motorlar · D-3 iş mili sürücüsü + 4 kW motor · D-4 FESTO valf adası, merkezleme, punta + basınç şalteri · D-5 Sick sensörler · D-6 el çarkı + ayak pedalı · D-7 E-stop, kapak kilidi, güvenlik rölesi / Safety PLC, ana kontaktör · D-8 CAM PC · D-9 Ethernet bağlantısı / switch · D-10 CNC ön panel USB portu
2 · Yazılım / firmware	Y-1 808D sistem yazılımı · Y-2 808D PLC programı (kapak, pnömatik mantığı) · Y-3 makine parametreleri (hız sınırları) · Y-4 sürücü firmware + parametreleri · Y-5 üreticinin CAM yazılımı · Y-6 CAM PC işletim sistemi + uzak masaüstü yazılımı · Y-7 G-kodu programları
3 · Hesaplar	H-1 CNC erişim seviyeleri (üretici / servis / kullanıcı parolası, varsayılan olabilir) · H-2 CAM PC ortak operatör hesabı · H-3 uzak destek hesabı
4 · Sertifika / anahtar	K-1 paylaşılan uzak destek parolası · K-2 fabrika ağı / Wi-Fi parolası
5 · Dış bağlantı	B-1 uzak destek bağlantısı (internet → CAM PC) · B-2 CAM PC'nin internet çıkışı · B-3 USB bellek (elle taşınan bağlantı)
6 · Kritik veri akışı	V-1 G-kodu: CAM PC → USB/Ethernet → CNC · V-2 parametre / PLC yedek arşivi · V-3 üreticiden gelen güncelleme dosyaları

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Zone	Varlıklar	Kritiklik
Z0 · Dış dünya	İnternet, üretici uzak servisi	Güvenilmez
Z1 · Ofis	Fabrika ofis ağı, ERP / e-posta, Wi-Fi	Düşük
Z2 · DMZ	Uzak erişim için jump server (hedef mimaride)	Tampon
Z3 · Mühendislik	CAM PC, üretici CAM yazılımı, program arşivi	Orta
Z4 · Makine	SINUMERIK 808D (CNC + PLC + panel), servo ve iş mili sürücüleri, motorlar, FESTO pnömatik, Sick sensörler, el çarkı / pedal, USB portu	Yüksek
Z5 · Safety	E-stop, kapak kilidi, punta basınç şalteri, güvenlik rölesi / Safety PLC, STO hattı, ana kontaktör	**En yüksek**

Hesaplar ve parolalar ayrı bir bölge değildir, bağlı oldukları cihazın kapısıdır: H-1 Z4'ün, H-2 Z3'ün, H-3 ve K-1 Z2'nin kapısıdır.

2 **Güvenlik rölesi / STO zincirini hangi bölgeye koydunuz? 808D'nin entegre PLC'si bu bölgeye girebilir mi? Neden?** UYARLANDI

Ayrı ve en korunan **Z5 Safety Zone**'a koyduk. Bu bölgenin ağ bağlantısı yok, sinyaller kabloyla (hardwired) gelir. 808D'nin entegre PLC'si bu bölgeye **giremez**: emniyet sınıfı değildir ve USB/Ethernet ile programlanabilir. Bölge içi güvenilir sayıldığı için CNC'yi ele geçiren kişi safety zincirine de ulaşırdı. CNC, safety'den sadece durum bilgisi okur (kapak kapalı mı, E-stop basılı mı), safety kararlarını değiştiremez.

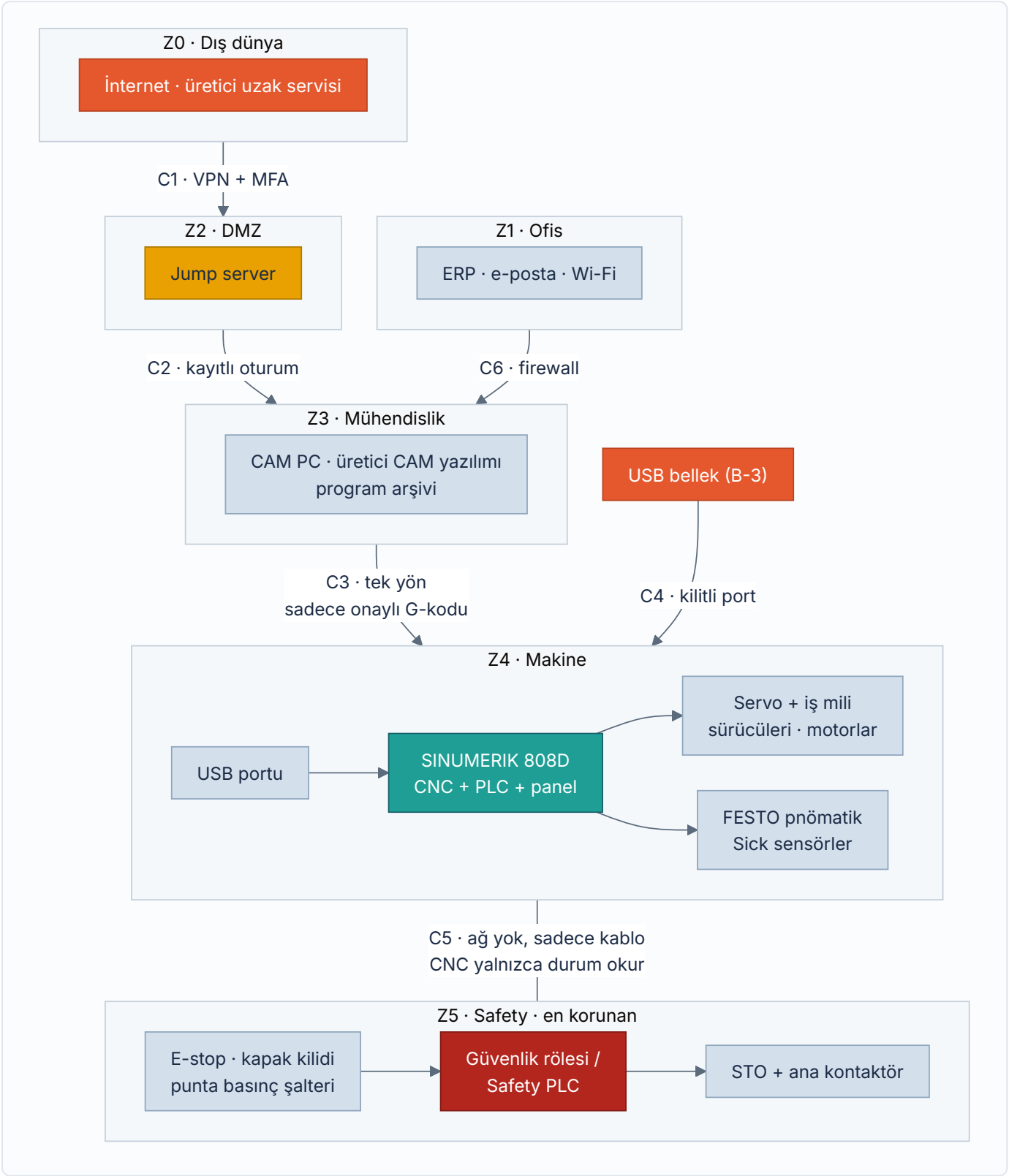
3 **Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?**

Conduit	Geçiş	Kontrol
C1	İnternet (üretici) → DMZ	Firewall'da sadece VPN, MFA, kişisel hesap, varsayılan kapalı erişim, oturum kaydı
C2	DMZ → Mühendislik (CAM PC)	Sadece jump server'dan, sadece gerekli protokol, oturum kaydı
C3	Mühendislik → Makine (Ethernet → 808D)	Tek yön, sadece onaylı G-kodu dosyası. Parametre ve PLC yazma kapalı, sadece CAM PC'nin adresine izin
C4	USB portu → Makine	Port kilidi, sadece kayıtlı ve taranmış USB. Program 3D önizleme ve kuru çalıştırmadan geçmeden üretime alınmaz
C5	Safety → Makine	Ağ yok, sadece kablo. CNC durum bilgisini okur, safety ayarı yalnızca yerinde, yetkili kişiyle ve kayıtla değişir
C6	Ofis → Mühendislik	Firewall, ofisten CNC'ye doğrudan yol yok. CAM PC'de e-posta ve web kullanılmaz

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçimimiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server:** üretici servisi CAM PC'ye ve 808D'ye doğrudan bağlanmaz, tek kontrollü giriş olur
Tünel?	Açık / VPN	**VPN:** Bursa'daki servis ile fabrika arasındaki trafik şifreli, dinlenemez ve araya girilemez
Kimlik?	Parola / MFA	**MFA:** paylaşılan uzak destek parolası çalınsa da tek başına yetmez
Hesap?	Paylaşılan / Kişisel	**Kişisel:** her teknisyene ayrı hesap, kim hangi parametreyi değiştirdi bilinir
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı:** program veya parametre değişirse kanıt olur (Makine Tüzüğü Ek III 1.1.9: müdahale kanıtı)
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı:** sadece iş emriyle ve bakım süresince açılır, makine üretimdeyken uzaktan yazma yapılmaz

Çıktı — Zone / Conduit Diagram



Ek sorularımız

4 **USB portu bir conduit midir? Neden?** EK SORU

Evet. Ağ kablosu olmasa da Makine Zone'a dışarıdan veri sokan bir geçiştir. G-kodu, parametre arşivi ve zararlı yazılım bu yoldan girebilir. Kontrolsüz USB, kontrolsüz bir conduit demektir. Bu yüzden diyagramda **C4** olarak işaretledik ve kilitli port + kayıtlı USB kuralı koyduk.

5 **Bu makinede en riskli conduit hangisi?** EK SORU

C1 + C3 birlikte. Uzak erişim (C1) internete açılan tek kapıdır. Bugünkü durumda (VS-4) CAM PC hem internete hem Ethernet ile CNC'ye bağlı olduğundan C3 köprü görevi görür: internetten giren kişi iki adımda iş mili hız sınırına ulaşır. Hedef mimaride bu köprüyü C3'teki "tek yön, sadece onaylı G-kodu" kuralı kırar.

Varsayımlar

VS-2, VS-4, VS-5 ve VS-6 bu föyde kullanıldı (bkz. Makine Profili).

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına, varlık listesi de **EP 01 Asset Inventory** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 3 · SCHNITZER 2×2 · CNC Ahşap Torna

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	23.10.2026

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır, insana zarar görünür kalır.
Schnitzer'in kapıları (Lab 2 envanterinden): B-1 uzak destek bağlantısı · D-10 / B-3 USB portu · D-9 Ethernet · H-1 CNC varsayılan erişim parolaları · H-2 ortak CAM PC hesabı · V-3 servis dizüstüsü / güncelleme dosyaları. Fiziksel sonuç adayları: dönen parçaya dolanma, fırlayan parça, kesilme, sıkışma.

Görev — senaryo kurun ve puanlayın

ID	Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R-01	**Fırsatçı dış** → internete açık uzak destek (B-1, paylaşılan parola) → CAM PC → Ethernet ile 808D'de iş mili azami hız parametresi yükseltilir → **SF-4 bozulur**, kütük fazla hızda çatlayıp fırlar → operatöre çarpma, ağır yaralanma	3	3	3	**27**	**1 · Kritik**
R-02	**Meraklı içeriden** → CNC varsayılan erişim parolası (H-1) → "parça yüklemesi yavaş" diyerek kapak açıkken harekete izin veren ayarı açar → **SF-2 bozulur** (kapak mantığı CNC'de ise, VS-3) → dönen parçaya kol/kıyafet dolanır, ağır yaralanma	3	3	1	**9**	**2 · Yüksek**
R-03	**Tedarik zinciri** → servis dizüstüsü / imzasız güncelleme (V-3) → değiştirilmiş PLC programı punta basınç kontrolünü atlar → **SF-3 bozulur**, basınç düşükken iş mili döner → parça puntadan kurtulup fırlar, ağır yaralanma	1	3	1	**3**	**3 · Düşük ⚑ S3 bayrağı**
R-04	**Fırsatçı dış** → uzak destek (B-1) → CAM PC fidye yazılımıyla şifrelenir → program arşivi kaybolur, üretim durur → kimse yaralanmaz (emniyet bulgusu değil)	3	1	3	**9**	**4 · Yüksek (S=1)**

Bantlar: **Kritik 18–27** · **Yüksek 9–17** · **Orta 4–8** · **Düşük 1–3**

Puan gerekçeleri

ID	L gerekçesi	S gerekçesi	E gerekçesi
R-01	Paylaşılan parola, otomatik tarama ve hazır araçla dakikalar içinde girilir	Fırlayan parça ağır ya da kalıcı yaralanma yapar	Bağlantı internetten sürekli açık
R-02	Varsayılan parola, makine başında herkes deneyebilir	Dolanma ağır ve kalıcı yaralanma yapar	Yalnızca makine başından, fiziksel erişimle
R-03	Tedarikçi altyapısını ele geçirmek gerekir, birden çok adım var	Fırlayan parça ağır yaralanma yapar	Sadece servis ziyaretinde, fiziksel bağlantıyla
R-04	R-01 ile aynı kapı, aynı L	Sadece üretim ve veri kaybı, yaralanma yok	R-01 ile aynı kapı, aynı E

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

R-01 (27, Kritik): kapı internete sürekli açık ve paylaşılan parolayla dakikalar içinde istismar edilebilir; zincir iş mili hız sınırını bozup fırlayan parçayla operatörü ağır yaralar.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet, **R-03 (L1 · S3 · E1 = 3, Düşük).** Risk Register'da **S3 bayrağıyla** işaretleyip ayrı S3 listesinde yönetime raporluyoruz. Skoru 9 olan ama kimseyi yaralamayan R-04'ün (fidye) **önüne** aldık. Bir önlem (imzalı güncelleme + değişiklik sonrası safety validation: kapak, E-stop ve punta testleri) ya da yazılı kabul kararı olmadan kapatılmaz.

> **Altın kural:** Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir. Bir adım daha gidin: bu, makinedeki insana ne yapar? R-04 bu yüzden S=1 aldı. Fidye sonrası operatör kontrolsüz eski bir programı USB ile yüklerse zincir fiziksele uzar, o zaman R-04 yeniden puanlanır.

Ek sorularımız

3 **R-01'in bugünkü ve önlemli hâli nasıl puanlanır?** EK SORU

Durum	Önlemler	L · S · E	Skor
Bugün	Mevcut hâl (VS-3, VS-4)	3 · 3 · 3	**27 · Kritik**
Erişim önlemleri	Jump server, VPN, MFA, kişisel hesap, varsayılan kapalı, C3'te parametre yazma kapalı	1 · 3 · 2	**6 · Orta** (S3 bayrağı sürer)
+ Emniyet bağımsızlığı	Hız sınırı CNC parametresinden bağımsız, emniyet sınıfı bir fonksiyonda	1 · 1 · 2	**2 · Düşük**

Erişim önlemleri L ve E'yi düşürür, S'yi ise yalnızca emniyet tasarımı düşürür. Bunun tasarımını Lab 4'te yaptık.

4 **Emniyete hiç dokunmayan bir siber senaryo (R-04) Register'a girmeli mi?** EK SORU

Evet, girmeli ama **S=1 ile ve emniyet bulgusu olarak değil.** R-04 bize iki şey söylüyor. Birincisi, R-01 ile aynı kapıyı kullanıyor, yani o kapıyı kapatmak iki riski birden düşürür. İkincisi, üretim baskısı elle müdahaleyi artırır. Matris bir araçtır, patron değil: R-04'ün skoru R-03'ten yüksek olsa da öncelik R-03'te.

Eylem planı (Risk Register'ın yönetim kolonu)

ID	Önerilen önlem	Sahip (RACI)	Hedef
R-01	Uzak erişimi kapat, jump server + VPN + MFA kur, C3'te parametre yazmayı kapat	A: Yönetim · R: OT + IT	30 gün (Kritik)
R-02	Varsayılan parolaları değiştir, erişim seviyelerini ayır, kapak mantığını safety zincirine taşı	A: Yönetim · R: Safety + Servis	90 gün
R-03	İmzalı güncelleme, servis dizüstüsü kontrolü, değişiklik sonrası safety validation	A: Yönetim · R: Servis + Safety	S3 listesi, yönetime rapor
R-04	CAM PC yedekleme + çevrim dışı program arşivi, CAM PC'de web / e-posta yok	A: Yönetim · R: IT	Planlı iyileştirme

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 4 · SCHNITZER 2×2 · CNC Ahşap Torna

Secure Remote Access

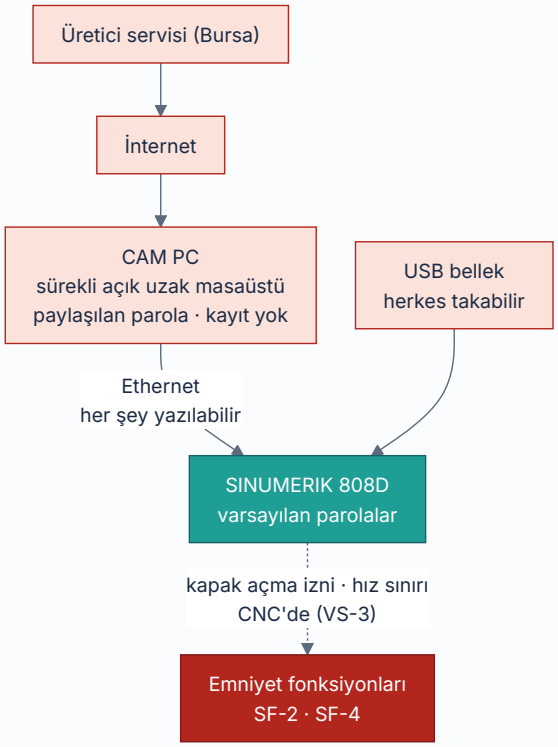
Çıktı: Secure Architecture

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	23.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

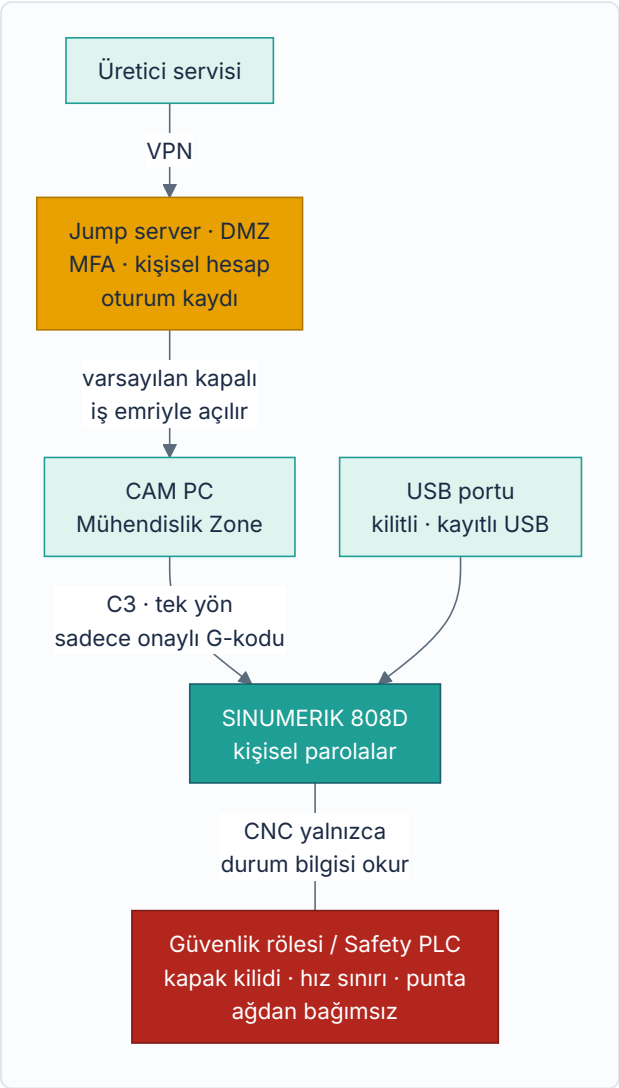
Görev A — mevcut → hedef

MEVCUT (savunmasız — kötü durum varsayımı VS-4, VS-6)



- Uzak destek yazılımı CAM PC'de sürekli açık, internetten doğrudan erişilebilir
- Teknisyenler ve operatörler aynı parolayı kullanıyor, MFA yok
- Erişim süresiz, fabrikadan onay alınmıyor
- Oturum kaydı yok: kim hangi programı veya parametreyi değiştirdi bilinmiyor
- CAM PC Ethernet ile CNC'ye doğrudan bağlı: PC'yi ele geçiren CNC'ye program ve parametre yazabiliyor
- USB portu açık, CNC erişim parolaları fabrika varsayılanı
- Kapak açma izni ve hız sınırı CNC'de, yani emniyet **bağımsız değil**

HEDEF (beş ilkeyle yeniden tasarım)



- **1 · Ara nokta:** üretici yalnızca DMZ'deki jump server üzerinden gelir. CAM PC ve 808D internete doğrudan açık değil
- **2 · Kişisel hesap:** her teknisyene ayrı hesap. CNC'nin varsayılan parolaları değişir, operatör / servis / üretici seviyeleri ayrılır
- **3 · MFA:** uzak girişte parola + ikinci faktör zorunlu
- **4 · Varsayılan kapalı, süre sınırlı:** erişimi fabrikadaki sorumlu iş emriyle açar, bakım bitince otomatik kapanır. Makine üretimdeyken uzaktan yazma yapılmaz
- **5 · Oturum kaydı:** kim, ne zaman, hangi dosya veya parametre. Değişiklik öncesi ve sonrası CNC arşiv yedeği alınır
- **Ek kural:** Ethernet'te (C3) yalnızca onaylı G-kodu tek yönde geçer, USB portu kilitlidir (C4)

Görev B — functional safety köprüsü

1 **Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?**

Fonksiyona bağlı. E-stop ve STO zinciri kablolu güvenlik rölesindeyse (VS-2) **E-stop etkilenmez**. Ama kapak açma izni ve iş mili hız sınırı 808D'nin PLC'sinde ve parametrelerinde ise (VS-3) **etkilenir**: CNC'ye ulaşan saldırgan hız sınırını yükseltebilir veya kapağın dönen parçada açılmasına izin verebilir. Erişim güvenliği girişi zorlaştırır ama tek başına yetmez; dijital kesişim noktası bir saldırı yolu bırakır.

2 **Kapak kilidi ve iş mili hız sınırının CNC'den ve uzak destek yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).** UYARLANDI

- **GR-1:** E-stop, kapak kilidi ve punta basınç kontrolü, CNC'nin standart PLC'sinden bağımsız, emniyet sınıfı bir kontrol zincirinde yürümeli. USB, Ethernet ve uzak destek yolundan okunabilir ama **değiştirilemez** olmalı.
- **GR-2:** Kapak kilidi, iş milinin durduğu emniyet sınıfında doğrulanmadan açılmamalı. CNC'nin "durdu" bilgisine güvenilmemeli.
- **GR-3:** İş milinin azami hızı, G-kodu ve CNC parametresinden bağımsız bir emniyet fonksiyonuyla sınırlanmalı.
- **GR-4:** Enerji kesildiğinde punta sıkması konumunu korumalı; parça dönerken bırakılmamalı.
- **GR-5:** Emniyet konfigürasyonundaki her değişiklik yalnızca makine başında ve yetkili kişiyle yapılmalı, kayda geçmeli ve ardından safety validation (kapak, E-stop, punta testleri) yapılmalı.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz, gereksinimi tanımlatır. Hangi ürünle karşılanacağı firmanın kararıdır.

Ek sorumuz

3 Saldırı zincirini hangi halkada kırıyoruz? EK SORU

Halka	Bu makinede	Kırma önlemi
Keşif	İnternette açık uzak destek görünür	Dışa açık hiçbir şey bırakma (jump server)
İlk erişim	Paylaşılan parolayla CAM PC'ye giriş	MFA + varsayılan kapalı
Yerleşme	Kalıcı uzak erişim veya yeni hesap	Kişisel hesap + oturum kaydı + hesap denetimi
Yanal hareket	CAM PC → Ethernet → 808D	C3: tek yön, sadece onaylı G-kodu
Etki	Hız sınırı veya kapak mantığı değişir	Emniyet bağımsızlığı (GR-1 … GR-5)

Erişim önlemleri ilk dört halkayı, emniyet bağımsızlığı son halkayı kırar. Biri kemer, biri askı: ikisi de şart. Lab 3'teki R-01 bu sayede 27'den 2'ye iner.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 Network Architecture + EP 06 Remote Access Procedure** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 5 · SCHNITZER 2×2 · CNC Ahşap Torna

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	30.10.2026

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**
Schnitzer bağlamı: Föydeki hayali "Component X" yerine makinemizin gerçek kontrol ünitesi için yayımlanmış **gerçek bir Siemens güvenlik bültenini** kullandık. Bileşen listesi Lab 2 envanterinden (Y-1 … Y-6) geliyor.

SBOM taslağı — makinedeki yazılımlar

EK SORU

SBOM olmadan bir CVE'nin bizi etkileyip etkilemediğini bilemeyiz. Bu yüzden önce makinenin yazılım listesini çıkardık. Sürümler üretici sayfasında yok, sahada kontrol ekranından okunacak (VS-7).

ID	Bileşen	Sağlayıcı	Sürüm	Nereden ulaşılır
Y-1	SINUMERIK 808D sistem yazılımı (CNC firmware + entegre yazılım güvenlik duvarı)	Siemens	Sahada okunacak (VS-7)	X130 Ethernet portu · USB
Y-2	808D PLC kullanıcı programı (kapak, pnömatik mantığı)	Schnitzer	Üreticiden istenecek	Ethernet · USB · servis
Y-3	Makine parametreleri (hız sınırları)	Schnitzer	Arşiv tarihi ile	Ethernet · USB · panel
Y-4	Servo ve iş mili sürücü firmware'i	Siemens	Sahada okunacak	Sürücü üzerinden, CNC aracılığıyla
Y-5	Schnitzer CAM yazılımı (2D → G-kodu)	Schnitzer	Üreticiden istenecek	CAM PC
Y-6	CAM PC işletim sistemi + uzak masaüstü yazılımı	Üçüncü taraf	Sahada okunacak	İnternet · fabrika ağı

Not: Y-5 için CRA kapsamında üreticiden **SBOM ve destek süresi** istenir. Bugün bu bilgi yok, bu da bir bulgu.

Verilen zafiyet kaydı

UYARLANDI

Alan	Değer
Bileşen	SINUMERIK 808D sistem yazılımı (Y-1), entegre yazılım güvenlik duvarı
Sürüm	V4.7 ve V4.8, yani **V4.91'den eski tüm sürümler**
CVE	**CVE-2018-11466** · Siemens SSA-170881 · CISA ICSA-18-345-02
Önem	**Critical (CVSS 10.0)**: ağdan, kimlik doğrulamasız, 102/tcp (ISO-TSAP) portuna özel paketle güvenlik duvarını çökertme veya kod yürütme
Yama	**Mevcut:** V4.91'e güncelleme (Siemens satış temsilcisinden temin edilir) + üreticinin önerdiği önlemler

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Şart	Bu makinede	Sonuç
Bileşen var mı?	Makinede SINUMERIK 808D kontrol ünitesi var	✅ Var
Sürüm etkileniyor mu?	Sürüm bilinmiyor. Kontrol ekranından okunacak, V4.91'den eskiyse etkilenir	⚠️ Doğrulanacak (VS-7)
Açık ulaşılabilir mi?	102/tcp, 808D'nin X130 Ethernet portundan erişilir. Bugünkü durumda CAM PC aynı ağda ve internete açık (VS-4), yani saldırgan iki adımda ulaşır	✅ Ulaşılabilir

Karar: Sürüm doğrulanana kadar makine **etkileniyor kabul edilir.** Sürüm V4.91 veya üstü çıkarsa kayıt "etkilenmiyor" olarak kapatılır, ama kanıtı (sürüm ekranının fotoğrafı) EP 10'a eklenir.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, otomatik olarak değil. CVSS açığın ciddiyetini ölçer, makinenin emniyetini değil. Önce **saldırı yolunu hemen kapatırız:** 808D'nin Ethernet bağlantısını CAM PC dışındaki her şeyden ayırır, uzak erişimi kapatırız. Yol kapandığında üretim devam edebilir. **Durdururuz ancak** istismar belirtisi varsa: beklenmeyen parametre değişikliği, CNC'nin kendiliğinden yeniden başlaması, açıklanamayan hız değişimi. O durumda makine güvenli duruma alınır, kayıtlar silinmeden korunur (Lab 6).

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. CNC firmware'i değişince makine üreticisinin PLC programı ve parametreleri yeni sürümle uyumsuz kalabilir. Sıra:

- **Yedek:** güncellemeden önce tam CNC arşivi alınır (PLC programı, makine parametreleri, programlar)
- **Uyumluluk onayı:** Schnitzer, PLC programının V4.91 ile çalıştığını yazılı onaylar
- **Test yeri:** üreticinin aynı kontrol ünitesine sahip test tezgâhı. Yoksa makinenin kendisi, **üretim dışı bir bakım penceresinde** ve geri dönüş planıyla
- **Geri dönüş:** sorun çıkarsa eski arşiv geri yüklenir
- **Kayıt:** kim, ne zaman, hangi sürümden hangisine (EP 11)

4 Bu yama bir safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Evet, etkiliyor kabul ediyoruz. Lab 1'deki varsayıma göre (VS-3) kapak açma izni ve iş mili hız sınırı CNC'nin PLC'sinde ve parametrelerinde. CNC firmware'ini değiştirmek bu fonksiyonların çalıştığı ortamı değiştirir. Nasıl anlarız:

- **Etki analizi:** yama hangi emniyet fonksiyonuna dokunuyor? Lab 1'deki SF listesi üzerinden tek tek bakılır
- **Fark kontrolü:** güncelleme öncesi ve sonrası PLC programı ile parametre arşivi karşılaştırılır. Hız sınırı değerleri aynı kalmalı
- **Fonksiyon testleri:** SF-1 E-stop durdurur · SF-2 kapak açıkken iş mili dönmez ve iş mili durmadan kapak açılmaz · SF-3 punta basıncı düşükken iş mili başlamaz · SF-4 azami hız aşılamaz
- **Kayıt:** test sonuçları imzalı olarak EP 15'e (Verification/Test) eklenir

Kablolu güvenlik rölesi zinciri (VS-2) firmware'den etkilenmez, ama yine de test edilir: "etkilenmez" bir beyandır, test ise kayıttır.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- **Ağ izolasyonu:** 102/tcp'ye yalnızca CAM PC ulaşır, başka hiçbir yerden ulaşılamaz (Lab 2, C3). Gerekirse Ethernet tamamen kapatılır, program aktarımı kontrollü USB ile yapılır (C4)
- **Güvenlik duvarı varsayılanları:** X130 portunda 4842/tcp ve 5900/tcp kapalı mı kontrol edilir (Siemens önerisi)
- **Uzak erişim:** varsayılan kapalı, jump server + VPN + MFA (Lab 4)
- **En az yetki:** kişisel hesaplar, değiştirilmiş varsayılan parolalar (aynı bültendeki yerel yetki yükseltme açıklarına karşı da)
- **İzleme:** CNC'nin beklenmedik yeniden başlamaları kaydedilir, parametre arşivi haftalık karşılaştırılır
- **Emniyet bağımsızlığı (en güçlü önlem):** GR-1 ... GR-4. CNC ele geçse bile kapak kilidi ve hız sınırı insanı korur
- **Kayıt:** EP 10'a "yama ertelendi" kararı, telafi önlemleri ve yeniden değerlendirme tarihi yazılır

Ek sorularımız

6 Aynı bültendeki CVE-2018-11457 (CVSS 9.8, web sunucusu 4842/tcp) bizi etkiler mi? EK SORU

Hayır. Siemens bülteninde 808D bu CVE için listelenmiyor, açık 828D ve 840D sl modellerini etkiliyor. Bileşen şartı sağlanmadığı için puanı ne kadar yüksek olursa olsun bizim için geçerli değil. Bazı ikincil veritabanları bunu farklı gösterebiliyor, bu yüzden karar her zaman **üreticinin kendi bültenine** göre verilir. Ders: yüksek CVSS gördüğünde panik yapma, önce üç şartı kontrol et.

7 CVE-2018-11465 (CVSS 7.8, yerel) ile CVE-2018-11466 (CVSS 10.0, ağ) arasında hangisi önce? EK SORU

CVE-2018-11466. Ağdan ve kimlik doğrulaması olmadan istismar edilir. CVE-2018-11465 ise makineye yerel erişim ve kullanıcı yetkisi gerektirir, yani yalnızca makine başından (Lab 3'teki E=1). İkisi de aynı güncellemeyle (V4.91) kapanır, ama yama gelene kadar telafi önlemlerinde öncelik ağ izolasyonundadır.

8 Bu CVE Risk Register'ı nasıl değiştirir? EK SORU

Lab 3'teki kural: yeni bir açık çıktığında L puanı değişir. Bu CVE için yeni bir satır açtık:

R-05: Fırsatçı dış → CAM PC (B-1) → fabrika ağı → 808D 102/tcp (CVE-2018-11466) → CNC'de kod yürütme → hız sınırı / kapak mantığı değişir (SF-4, SF-2) → fırlayan parça veya dolanma, ağır yaralanma.

Durum	L · S · E	Skor
Bugün (yamasız, CAM PC aynı ağda)	3 · 3 · 2	**18 · Kritik**
Ağ izolasyonu (102/tcp yalnız CAM PC'den, uzak erişim kapalı)	3 · 3 · 1	**9 · Yüksek**
Yama V4.91 + izolasyon	1 · 3 · 1	**3 · Düşük ⚑ S3**
+ Emniyet bağımsızlığı	1 · 1 · 1	**1 · Düşük**

L=3 çünkü kimlik doğrulama gerekmiyor ve açık kamuya duyurulmuş. E=2 çünkü CNC doğrudan internette değil, fabrika ağından ulaşılıyor. Yama L'yi, izolasyon E'yi düşürür. S'yi yine yalnızca emniyet tasarımı düşürür.

Vulnerability Decision (föyün çıktısı)

Alan	Karar
Kayıt	V-01 · CVE-2018-11466 · SINUMERIK 808D < V4.91
Etkileniyor mu?	Sürüm doğrulanana kadar **evet** (VS-7)
Hemen	Ağ izolasyonu + uzak erişim kapalı (bugün)
Karar	**Yamala:** V4.91, üretici onayı + test + safety validation sonrası

Alan	Karar
Sahip (RACI)	A: Yönetim · R: OT + Servis (Schnitzer) · C: Safety
Hedef tarih	30 gün (Kritik bant)
Yama olmazsa	Telafi önlemleri (soru 5) + 90 günde yeniden değerlendirme

Varsayımlar

Yeni varsayım VS-7: CNC sistem yazılımının sürümü bilinmiyor. Kötü durum olarak V4.91'den eski kabul edildi. VS-2, VS-3 ve VS-4 de bu föyde kullanıldı (bkz. Makine Profili).

Kaynaklar

- Siemens SSA-170881 — SINUMERIK güvenlik bülteni
- CISA ICSA-18-345-02 özeti
- CVE-2018-11465 kaydı

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 SBOM · EP 10 Vulnerability Records · EP 11 Patch/Update Records** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 6 · SCHNITZER 2×2 · CNC Ahşap Torna

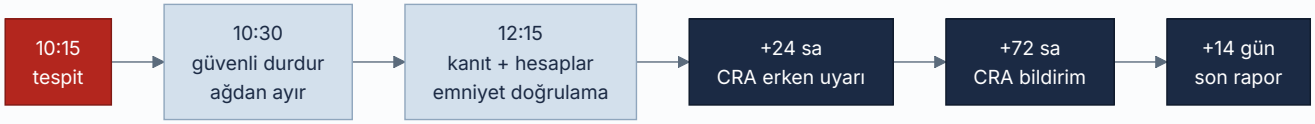
CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	06.11.2026

Senaryo UYARLANDI: Saat 10:15. CAM PC'deki uzak destek hesabına (H-3) gece 03:00'te tanınmayan bir konumdan girilmiş. Oturumda CNC'ye (808D) Ethernet üzerinden bir parametre arşivi gönderilmiş olabilir. **İş mili hız sınırı ve kapak kilidi ayarları henüz doğrulanmadı.** Makine çalışıyor, operatör parça yüklüyor. Vardiya sorumlusu sizsiniz.
Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24 sa / 72 sa / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır, ezber değil. Bu olay, Lab 3'teki **R-01** senaryosunun gerçekleşmesidir.

Incident Workflow — zaman çizgisi



Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Kimi ararım: üretim müdürü (karar yetkisi), İSG / safety sorumlusu, OT-IT sorumlusu ve **Schnitzer servisi**. Servisi bilinen telefon numarasından ararım, ele geçirilmiş uzak destek kanalından değil.

İlk üç eylem:

- **Güvenli durdurma:** çalışan program bitirilir veya besleme durdurulur, iş mili durur, operatör makineden uzaklaştırılır. Hız sınırı ve kapak ayarı doğrulanmadığı için makine **çalışmaya devam edemez.** Reset atılmaz, enerji kesilmez
- **Ağdan ayırma:** CAM PC'nin internet kablosu ve CNC'nin Ethernet kablosu çıkarılır. Cihazlar **kapatılmaz**, açık kalır ki bellekteki iz kaybolmasın
- **Kayıt başlatma:** olay kaydı açılır. Saat, kim neyi gördü, ekranların fotoğrafı. Makineye "kullanılmaz — olay incelemesi" etiketi asılır

2 İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt)? Hangi hesap kapatılır? UYARLANDI

Emniyet güvende mi? Makine durdurulduğu için insan şu an güvende, ama emniyet fonksiyonları doğrulanmadan **yeniden çalıştırılmaz.** Doğrulama sırası:

- CNC'nin mevcut ("bulunduğu gibi") arşivi alınır, son bilinen sağlam arşivle karşılaştırılır (Lab 5 fark kontrolü)
- Hız sınırı (SF-4) ve kapak mantığı (SF-2) değerleri tek tek kontrol edilir
- Kablolu E-stop ve STO zinciri (SF-1) test edilir

Korunan kanıt:

- CNC'nin bulunduğu gibi arşivi, yeni ve temiz bir USB'ye alınır, özet değeri (hash) kaydedilir
- CNC alarm ve olay geçmişi
- CAM PC: uzak masaüstü bağlantı kayıtları, Windows olay günlükleri, mümkünse disk imajı
- Modem / firewall kayıtları (03:00 girişinin IP adresi)

Kapatılan hesaplar: uzak destek hesabı (H-3) ve paylaşılan parolası (K-1) devre dışı bırakılır. CAM PC'nin ortak operatör hesabının (H-2) parolası kanıt alındıktan sonra değiştirilir.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

- **Ne oldu:** uzak destek hesabıyla yetkisiz erişim, gece 03:00, CNC'ye parametre gönderilmiş olabilir
- **Hangi ürün:** Schnitzer 2 Eksen 2 Ünite, seri numarası, CNC sürümü (Lab 5, VS-7)
- **Aktif istismar şüphesi var mı:** evet, kötü niyetli erişim varsayılıyor
- **Yayılma riski:** aynı uzak destek parolası başka müşterilerin makinelerinde de kullanılıyorsa olay tek fabrikayla sınırlı değildir. Bu sorunun cevabı Schnitzer'den istenir
- **İlk önlemler:** makine durduruldu, ağdan ayrıldı, hesap kapatıldı

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

Konu	İçerik	Kim (RACI)
Kök neden	Sürekli açık uzak masaüstü, paylaşılan parola, MFA yok, kayıt yok (Lab 4 MEVCUT)	R: OT-IT · C: Schnitzer
Etki	Hangi parametreler değişti (arşiv farkı), emniyet fonksiyonu etkilendi mi, yaralanma var mı, üretim kaybı	R: Safety + OT · C: Üretim
Önlem	Hesap kapatıldı, makine ağdan ayrıldı, sağlam arşiv geri yüklenecek, Lab 4 hedef mimariye geçiş	R: OT-IT + Schnitzer
Bildirim	CRA bildirimini üretici olarak Schnitzer yapar, fabrika gereken bilgileri sağlar	A: Yönetim · R: Schnitzer

5 14 gün — son rapor: Hangi loglar / kayıtlar korunmuş olmalı?

- Uzak erişim bağlantı kayıtları ve modem / firewall kayıtları
- CAM PC olay günlükleri ve disk imajı
- CNC alarm geçmişi, bulunduğu gibi arşiv ve sağlam arşiv (hash değerleriyle)
- Arşiv farkı: hangi parametre, eski değer → yeni değer
- Yeniden başlatma öncesi safety validation test kayıtları (EP 15)
- Olay zaman çizelgesi ve iletişim kaydı: kim kime ne zaman haber verdi

Ders: kayıtlar 7 gün tutuluyorsa 14 günlük rapor için kanıt kalmaz. Bu yüzden yeni gereksinim: **uzak erişim ve güvenlik duvarı kayıtları en az 90 gün saklanır.**

> **En sık hata:** "Resetleyip devam edelim." O düğme kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Ek sorularımız

6 Makineyi yeniden çalıştırmak için hangi koşullar sağlanmalı? EK SORU

#	Koşul	Kanıt
1	Kanıtlar alındı ve hash değerleri kaydedildi	Olay kaydı
2	Son bilinen sağlam arşiv geri yüklendi, fark incelendi	Arşiv farkı
3	SF-1 … SF-4 fonksiyon testleri geçti	İmzalı test formu (EP 15)
4	Uzak destek hesabı kapalı, paylaşılan parola iptal	Hesap listesi
5	Uzak erişim kapalı kalır veya Lab 4 hedef mimariyle açılır	Ağ şeması (EP 02)
6	Safety sorumlusu ve üretim müdürü yazılı onay verdi	İmza

Biri bile eksikse makine çalışmaz.

7 CRA bildirimi kimin yükümlülüğü: bizim mi, Schnitzer'in mi? EK SORU

CRA'nın bildirim yükümlülüğü **ürünün üreticisindedir.** Schnitzer, aktif olarak istismar edilen bir zafiyeti veya ürünün güvenliğini etkileyen ciddi bir olayı ENISA'nın tek raporlama platformu üzerinden yetkili CSIRT'e bildirir. Bu yükümlülük 11 Eylül 2026'dan beri geçerli. Son raporun süresi olayın türüne göre değişir: zafiyette düzeltici önlem çıktıktan sonra 14 gün, ciddi olayda bildirimden sonra 1 ay. Fabrika olarak bizim görevimiz üreticiye **hemen** haber vermek ve kanıtı sağlamaktır. Gönüllü olarak ulusal CERT'e (USOM) de bilgi verebiliriz. Ders: kimin bildireceği olaydan önce, sözleşmede ve EP 13'te yazılı olmalı.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 7 · SCHNITZER 2×2 · CNC Ahşap Torna

AI Safety Challenge

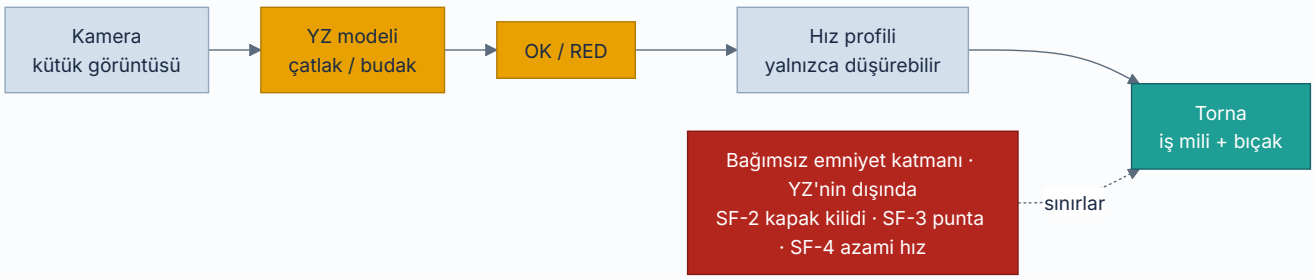
Çıktı: AI Fail-Safe Decision

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	06.11.2026

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin dışında tanımlanmalıdır. Araçlar: **fail-safe · human override · monitoring · confidence threshold · fallback.**

Senaryo UYARLANDI: Makinemizde bugün YZ yok. Schnitzer'e **YZ'li görsel kütük kontrolü** eklenmesi planlanıyor ve proje aşamasında değerlendirme yapıyoruz. Kamera, yüklenen kütükte çatlak ve budak arar. Sonuç iş milinin hız profilini seçer: sağlam kütük normal hızda, şüpheli kütük ret. Bu, Lab 1'deki en ağır tehlikeye bağlı: **çatlak kütük yüksek hızda fırlar.**

Sistem zinciri



Tasarım kararı: YZ bir **kalite** fonksiyonudur, emniyet fonksiyonu değildir. YZ ne derse desin, azami hız, kapak kilidi ve punta kontrolü YZ'den bağımsız çalışır (Lab 4, GR-1 … GR-4).

Görev — üç başarısızlıkta güvenli davranış

1 **Model yanlış sınıflandırdı: çatlak kütüğe OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?** UYARLANDI

Bu durumda çatlak kütük normal hızda döner. Sistem bunu YZ'ye güvenmeden şöyle karşılar:

- **Emniyet katmanı sabit kalır:** azami hız (SF-4) kütük kesitine göre YZ'den bağımsız sınırlı, kapak (SF-2) kapalı ve kilitli. Parça çatlasa bile insan kapalı kapağın arkasında
- **İkinci kontrol (monitoring):** ilk devirlerde iş mili titreşimi ve motor akımı izlenir. Anormal değerde iş mili kontrollü durur
- **İnsan kontrolü:** operatör kütüğü yüklerken gözle bakar ve şüpheliyse RED verebilir. İnsan her zaman **daha güvenli** yönde karar verebilir
- **Öğrenme:** yanlış OK'ler kaydedilir. Model yeniden eğitilirse bu bir değişikliktir: doğrulama testi olmadan devreye alınmaz (EP 14, EP 15)

2 Girdi manipüle edildi: kamera verisi bozuk / sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Nasıl fark edilir:

- Aynı görüntü tekrar tekrar geliyorsa (görüntü özeti aynı) donmuş veya sahte akış
- Görüntünün zaman damgası, parça var sensörünün (Sick) tetik anıyla uyuşmuyor
- Parlaklık, odak ve bulanıklık kontrolleri sınır dışında
- Kamera kablolu olarak Makine Zone'da (Lab 2) bağlı. Ağdan gelen görüntü kabul edilmez

Şüpheli girdide: fail-safe → RED. Kütük işlenmez, alarm verilir, operatöre sorulur. Sorun sürerse YZ devre dışı kalır ve **fallback** moduna geçilir: tüm kütükler gözle kontrol edilir, düşük hız profili kullanılır. Şüpheli girdide asla OK verilmez.

3 Confidence düştü: model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

- **Eşik asimetrik:** OK için yüksek güven gerekir (örneğin ≥ 0,95). RED için düşük güven bile yeterlidir, çünkü ret her zaman güvenli yöndür
- **Sayı tahminle konmaz:** eşik, doğrulama veri setinde "yanlış OK" oranı kabul edilen sınırın altında kalacak şekilde ayarlanır ve test kaydına yazılır (EP 15)
- **Eşik altında → insana sor:** kütük bekletilir, operatör karar verir. Makine durmaz, sadece o kütük işlenmez
- **Belirsizlik çoğalırsa → fallback:** bir vardiyada belirsiz kararlar belirli bir oranı aşarsa (örneğin %10) YZ devre dışı kalır ve gözle kontrol + düşük hız moduna geçilir. Sebep araştırılır: ışık, lens kirlenmesi, farklı ağaç türü

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığımız güvenli davranış	Kavram
Model yanlış sınıflandırdı	Emniyet katmanı YZ'den bağımsız (azami hız, kapak, punta). Titreşim ve akım izlenir, anormalse kontrollü durdurulur. Operatör her zaman RED verebilir	**fail-safe · monitoring · human override**
Girdi manipüle edildi	Tekrarlanan görüntü, zaman uyuşmazlığı ve kalite kontrolleri. Şüphede RED + alarm, sürerse YZ kapatılır	**monitoring · fail-safe · fallback**
Confidence düştü	OK için yüksek, RED için düşük eşik. Eşik altında operatöre sorulur, belirsizlik artarsa gözle kontrol + düşük hız	**confidence threshold · human override · fallback**

Ek sorularımız

4 YZ iş mili hızını artırabilir mi? EK SORU

Hayır, yetkisi tek yönlüdür. YZ hızı yalnızca düşürebilir veya kütüğü reddedebilir. Azami hız, CNC parametresinden ve YZ'den bağımsız emniyet fonksiyonunda (SF-4, GR-3) belirlenir. Bir saldırgan veya hatalı model "hızı artır" derse bile sınır aşılamaz. Bu, Lab 3'teki S puanını YZ'den bağımsız tutar.

5 YZ bir emniyet fonksiyonu olsaydı ne değişirdi? EK SORU

Makine Tüzüğü 2023/1230 Ek I Bölüm A'ya göre, emniyet fonksiyonunu sağlayan ve kendi kendine öğrenen (makine öğrenmeli) sistemler **yüksek riskli** sayılır ve onaylanmış kuruluş değerlendirmesi gerektirir. Kendi kendine öğrenen bir modelin her davranışını önceden test etmek de mümkün değildir. Bu yüzden tasarım kararımız net: YZ **kalite** kontrolü yapar, **emniyet** kararı YZ'nin dışında kalır. Prediction ≠ Safety.

6 YZ modeli bir siber varlık mı? Önceki lablara ne ekler? EK SORU

Evet. Model dosyası, eğitim verisi ve kamera yeni varlıklardır:

- **Lab 2:** envantere eklenir (kamera = donanım, model = yazılım, eğitim verisi = kritik veri akışı)
- **Lab 3:** yeni tehdit "veri zehirlenmesi", yani çatlak örneklerin "sağlam" diye etiketlenmesi. Emniyet katmanı YZ dışında olduğu için S düşük kalır
- **Lab 5:** model ve kütüphaneleri SBOM'a girer, zafiyetleri takip edilir
- **Lab 6:** model değişikliği beklenmedikse olay olarak ele alınır

---

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 Safety Functions + EP 15 Verification/Test** başlığına oturur. Durum: **Taslak**.

STRATEJİK DEĞERLENDİRME · SCHNITZER 2×2 · CNC Ahşap Torna

SWOT Analizi

Dayanak: Lab 1–4

Ad Soyad	Öğrenci No	Grup	Tarih
Yusuf Kaymaz	230541084	Gündüz-B	23.10.2026

Amaç: Makineyi "iyi mi, kötü mü" diye değil, **20 Ocak 2027'de siber güvenlik CE'nin ön şartı olduğunda** nerede durduğuna göre değerlendirmek. İç faktörler (S, W) makinenin kendisinden, dış faktörler (O, T) mevzuat ve tehdit ortamından gelir. Her madde bir lab çıktısına bağlıdır.

S · Güçlü yönler (iç)

- **Endüstriyel ve iyi belgelenmiş kontrol ekosistemi:** Siemens CNC (SINUMERIK 808D), Siemens servo sürücüler ve motorlar. Üreticinin güvenlik bültenleri ve yamaları takip edilebilir, bu da Lab 5'te SBOM ve CVE eşleştirmesini kolaylaştırır.
- **Emniyet bağımsızlığı için donanım altyapısı var:** sürücüler STO destekliyor (Lab 1, SF-1). Emniyeti CNC'den ayırmak sıfırdan tasarım gerektirmiyor.
- **Küçük ve sayılabilir saldırı yüzeyi:** 2 eksen, tek CNC, 3 dış bağlantı ve 28 kalemlik envanter (Lab 2). Tamamı yönetilebilir boyutta.
- **Tanınmış bileşenler:** FESTO pnömatik, PMI lineer sistem, Sick sensörler. Yedek parça ve dokümantasyon kolay bulunur.
- **Yerli üretici (Bursa) ve 24/7 destek:** teknik dosyaya, değişiklik taleplerine ve güvenli uzak destek kurulumuna ulaşmak kolay.

W · Zayıf yönler (iç)

- **Kanıt eksikliği:** üretici sayfası emniyet donanımını (kapak kilidi, güvenlik rölesi) ve uzak erişim yöntemini belgelemiyor. Evidence Pack'te başlıkların çoğu "Yok" veya "Taslak" durumunda (VS-1 … VS-6).
- **Emniyet bağımsızlığı belirsiz:** kapak açma izni ve hız sınırı CNC'nin standart PLC'sinde olabilir (VS-3). Lab 3'te R-01 ve R-02'yi bu zayıflık yaratıyor.
- **Kontrolsüz program yolu:** USB ile her programın yüklenebilmesi ve G-kodu doğrulamasının olmaması (Lab 2, C4).
- **Hesap zayıflığı:** fabrika varsayılanı CNC parolaları ve paylaşılan hesaplar (H-1, H-2, K-1).
- **Üreticiye ait CAM yazılımı:** SBOM'u, güncelleme imzası ve destek süresi bilinmiyor (V-3, Lab 3'te R-03).

O · Fırsatlar (dış)

- **Makine Tüzüğü 2023/1230 ile erken uyum:** Ek III 1.1.9 (bozulmaya karşı koruma) ve 1.2.1 (kontrol sistemlerinin dayanıklılığı) bugünden karşılanırsa, makine 2027'de CE'yi siber gerekliliklerle birlikte alır. Bu AB pazarı için zorunluluk, makinenin satıldığı diğer pazarlarda (İngiltere ve ABD bayileri) ise bir güven avantajıdır.
- **CRA ile süreç kurma:** SBOM, zafiyet yönetimi ve 24 sa / 72 sa / 14 gün bildirim zinciri üretici için bir "güvenli tasarım" referansına dönüşebilir.
- **Ucuz önlemlerle büyük etki:** uzak erişimi jump server + MFA arkasına alıp varsayılan kapalı yapmak R-01'i 27'den 6'ya indirir (Lab 3). Varsayılan parolaları değiştirmek R-02'nin L puanını 3'ten 1'e düşürür. Bunlar bütçe değil, disiplin ister.
- **Güvenli uzak destek bir hizmet olabilir:** jump server + VPN + MFA ile kurulan destek altyapısı (Lab 4), servis maliyetini düşürürken güveni artırır.

T · Tehditler (dış)

- **Fırsatçı dış saldırganlar:** internete açılan uzak masaüstü araçları otomatik olarak taranır. Hedef seçilmez, bulunur (Lab 3, R-01 ve R-04).
- **Tedarik zinciri:** imzasız güncelleme veya servis dizüstüsü üzerinden değiştirilmiş PLC mantığı (R-03, S3 bayrağı).
- **Mevzuat yaptırımı:** 20 Ocak 2027'den sonra geçiş dönemi yok, siber gereklilikleri karşılamayan makine CE alamaz. CRA cezası 15 M€'ya veya cironun %2,5'ine kadar çıkabilir.

- **Kontrol ünitesinin yaşam döngüsü:** CNC veya sürücü üreticisinin desteği biterse yama gelmez ve L puanları zamanla yükselir.
- **İnsan faktörü:** "hat yavaş, hızı açayım" refleksi (R-02). Eğitim ve yetki ayrımı yoksa en iyi mimari bile delinir.

SWOT matrisi — çıkan stratejiler

	Fırsatlar (O)	Tehditler (T)
Güçlü (S)	**SO:** STO altyapısını kullanarak emniyeti CNC'den ayır, 2027 CE dosyasına "emniyet bağımsızlığı" kanıtı olarak koy	**ST:** Siemens güvenlik bültenlerini takip eden bir SBOM / yama süreci kur, kontrol ünitesinin yaşam döngüsü riskini erken gör
Zayıf (W)	**WO:** Ucuz önlemleri (parola, USB, varsayılan kapalı erişim) 30 gün içinde yap, varsayımları üreticiden doğrulat ve Evidence Pack'i "Taslak"tan "Var"a çek	**WT:** Kapak kilidi ve hız sınırı CNC'de kaldıkça R-01 / R-02 yaşar. Bu, en yüksek öncelikli tasarım değişikliğidir

Öncelikli 5 aksiyon

#	Aksiyon	Kaynak	Etki
1	Uzak erişimi kapat, jump server + VPN + MFA ile yeniden aç	Lab 4, R-01	27 → 6
2	CNC varsayılan parolalarını değiştir, erişim seviyelerini ayır	Lab 2, R-02	L 3 → 1
3	Kapak kilidi, hız sınırı ve punta kontrolünü bağımsız emniyet zincirine al (GR-1 … GR-4)	Lab 4, SF-2 / SF-3 / SF-4	S 3 → 1
4	USB portunu kilitle, programı 3D önizleme + kuru çalıştırma onayıyla üretime al	Lab 2, C4	Kontrolsüz conduit kapanır
5	VS-1 … VS-6 varsayımlarını üreticiden yazılı olarak doğrulat, Evidence Pack'i güncelle	Makine Profili	Beyan → kayıt